SonarQube

Continuous code quality inspection

Isaac Lowe

Agenda

1. Background / History
2. Benefits
3. Components Explained
4. Summary

Background / History

An open-source platform for continuous inspection of code quality: it analyzes source code for bugs, vulnerabilities, and maintainability problems.

- Made by SonarSource, a Swiss company founded in 2008
- Static analysis: reads code without running it, 30+ languages
- Server (self-hosted), Cloud (formerly SonarCloud), IDE (formerly SonarLint)
- Linter vs. SonarQube: per-file style rules vs. project-wide quality over time, with a dashboard and pass/fail gates

Benefits

- Catches bugs and vulnerabilities before production
- Tracks technical debt (estimated time to fix)
- Integrates with CI/CD and can block failing merges
- Clean as You Code: focus on new code, not legacy
- Shared, objective quality standard for the team
- Feedback in pull requests and in the IDE

Issue Types

Bugs

Reliability. Code likely to be wrong, like a null pointer dereference.

Vulnerabilities

Security. Exploitable weaknesses, like SQL injection or hardcoded credentials.

Code smells

Maintainability. Works, but is hard to maintain: complex methods, dead code.

Hotspots

Security-sensitive code a human must review.

Each area gets an A to E rating.

Other Metrics

Metric	What it shows
Coverage	% of code exercised by tests (imported from JaCoCo, coverage.py, etc.)
Duplications	% of repeated code
Technical debt ratio	Cost to fix vs. cost to write the code
Cognitive complexity	How hard code is to understand

Quality Profiles and Gates

Quality Profile

The set of rules applied per language.

Quality Gate

Pass/fail conditions. Default "Sonar way", on new code:

- No new issues
- All hotspots reviewed
- Coverage at least 80%
- Duplication 3% or less

Architecture and Workflow

1. Push
Developer pushes code

2. Scan
CI runs the scanner

3. Server
Web UI, compute engine, search

4. Store
Database (PostgreSQL)

5. Result
Dashboard and gate pass/fail

Scanner options: SonarScanner CLI, Maven, Gradle, .NET.

Summary

1. Background: static-analysis platform from SonarSource
2. Benefits: catches problems early, enforces standards in CI
3. Components: issues, metrics, quality gates, scanner to server to dashboard

References

- https://en.wikipedia.org/wiki/SonarQube
- https://docs.sonarsource.com/sonarqube